

VERITRUST

IMPLEMENTATION HANDBOOK | 11 AUGUST 2026

Phishing Detection Architecture Blueprint

An evidence-first implementation plan for raw email, authentication, sender identity, content intelligence, cross-engine routing, training and safe release.

- Repository-grounded findings and ordered remediation tickets
- Hugging Face candidates, parameters and model registry contract
- SPF, DKIM, DMARC, ARC and trust-boundary implementation
- Interactive discovery worksheet and production checklist

Status: implementation-ready design; every model remains benchmark and governance gated

Scope: phishing evidence only; the Unified Gateway remains final action authority



How to use this handbook

This is a build specification, not a promise of perfect detection

No classifier, authentication protocol or heuristic proves that an email is safe. This design preserves observed facts, provenance, uncertainty and failure as separate evidence. Execute D0-D8 in order; do not let a candidate model influence production policy before the benchmark and calibration gates pass.

First decision

Freeze the exact repositories and revisions behind HF_PHISHING_MAILGUARD_MODEL and HF_PHISHING_CORTEX_MODEL. The repository hides both identifiers. The current label normalizer resembles a four-class email/URL dataset, but resemblance is not proof of the deployed model.

Document markers

Marker	Meaning
REQUIRED	Must pass before the capability may influence production policy.
CANDIDATE	Shortlisted component; not approved until local benchmark, security and license review.
INITIAL	A versioned starting limit or hyperparameter; tune from measured data.
SHADOW	Runs without changing user-facing state or Gateway action.

Audience

- Engineering leads: Sections 1-5, 13-15 and 19-24.
- ML engineers: Sections 8-12 and 16-18.
- Mail/security engineers: Sections 5-7, 13-14 and 21-22.
- Product and operations: Sections 2, 15, 19-20 and 23-25.

Table of contents

How to use this handbook	2
First decision	2
Document markers	2
Audience	2
Table of contents	3
1. Executive implementation decision	6
Release blockers found in the repository	6
Target outcome	6
2. Scope, modes and non-goals	7
Capability matrix	7
Non-goals	7
3. Current project architecture and deep findings	7
Implemented request paths	7
MailGuard normalizer	8
Cortex generative path	8
Rule and fallback path	8
4. Target service architecture	8
Service boundaries	9
Queue topology	9
5. Canonical artifacts and bounded MIME parsing	9
Immutable EmailArtifact	9
INITIAL parsing budgets	9
Parser implementation	9
6. Authentication evidence: SPF, DKIM, DMARC and ARC	10
Evidence flow	10
Protocol contract	10
Critical provenance rules	10
7. Sender identity and relationship graph	11
Typed edges	11
Normalization	11
8. Content intelligence and deterministic features	12
Semantic categories	12
Deterministic feature policy	12
9. Hugging Face and model portfolio	12
Recommended portfolio	13
Why these roles are separate	13

10. Exact model contracts and runtime parameters	13
Classifier contract	13
Recommended inference parameters	14
11. Model registry and pre-inference resolution	14
Required control flow	14
Registry record	14
Promotion gates	14
12. Scoring, calibration and abstention	15
Specialist state machine	15
Keep sources independent	15
INITIAL policy-independent bands	15
13. Cross-engine routing and evidence graph	15
Child artifacts	15
Routing rules	15
14. API and evidence data contracts	16
Ingress endpoints	16
Phishing Evidence bundle	16
Contract rules	16
15. Data acquisition, labeling and governance	16
Data portfolio	16
Label ontology	17
16. Training recipes	17
A. Email/SMS DistilBERT baseline	17
B. Multilingual mDeBERTa	17
C. Structured feature model	17
D. Generative semantic extractor	17
17. Leakage-safe splits and benchmark	18
Split before tokenization or augmentation	18
Required metrics	18
Promotion rule	18
18. Robustness, red-team and test plan	18
Test suites	18
Golden fixtures	18
19. Ordered roadmap and implementation tickets	19
D0-D8 delivery gates	19
First two implementation sprints	19
20. Product and UI implementation	20
User-facing modes	20

Result presentation 20

21. Scaling and deployment topology 20

 Workload classes 20

 Deployment controls 20

22. Security, privacy and licensing 21

 Threat controls 21

 Licensing decisions 21

23. Observability, drift and incident operations 21

 Telemetry 21

 Drift and retraining 21

 Runbooks 21

24. Interactive implementation worksheet 22

 Current MailGuard contract 22

 Current Cortex contract 22

 Target operating context 23

 Trusted receiver and infrastructure 23

25. Interactive production checklist 24

 Truth, inputs and failure behavior 24

References and source notes 25

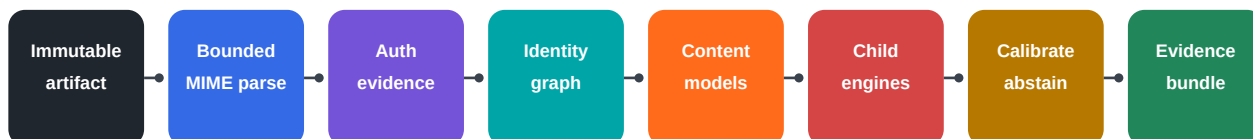
1. Executive implementation decision

Build phishing detection as an evidence pipeline over three explicit input modes. Parse and hash artifacts first; authenticate only with adequate provenance; model content separately from identity; route child URLs and images to specialist engines; then emit a bounded Phishing Evidence bundle. The Gateway, not this engine, maps evidence to allow, warn, quarantine or review.

Release blockers found in the repository

Priority	Finding	Required correction
P0	Exact MailGuard and Cortex model identifiers are hidden behind environment variables.	Resolve repository, immutable revision, task, tokenizer, labels and license before inference.
P0	MailGuard collapses four labels into binary and guesses unknown top-label semantics.	Use a registry label contract; reject unknown, missing, duplicate or non-finite outputs.
P0	Provider failures can become ok=true through English regex fallback.	Return FAILED or DEGRADED evidence; never fabricate a model result or a benign state.
P0	Cortex parses free-form JSON-like text and can fail open to Legitimate.	Remove it from verdicting; schema-validate bounded semantic fields in SHADOW only.
P0	Only pasted text is accepted; no raw .eml, MIME, authentication or relationships.	Add versioned plain_text, raw_eml and trusted_receiver_event contracts.
P1	Model score and hand rules are blended without calibration.	Keep sources independent, calibrate on deployment data and add abstention.
P1	The UI stores a 500-character preview even when retain_text is false.	Honor retention policy end-to-end; migrate previews to explicit opt-in/redaction.
P1	Gateway model registry resolution occurs after inference.	Resolve and authorize immutable model version before provider execution.

Target outcome



Specialist evidence remains independent; only the Gateway owns user-facing actions

Competitive advantage

The defensible product is not one larger classifier. It is trustworthy provenance, capability-aware modes, sender/link relationship evidence, calibrated abstention, cross-engine correlation, reproducible model versions and operational feedback loops.

2. Scope, modes and non-goals

PLAIN TEXT	RAW .EML	TRUSTED RECEIVER
subject/body	immutable bytes	raw .eml + SMTP
semantic model	MIME + headers	SPF + trusted auth
URLs to Link	DKIM + relations	strongest identity

Never claim sender authentication in a mode that lacks trustworthy SMTP evidence

Capability matrix

Capability	plain_text	raw_eml	trusted_receiver_event
Content semantics	Yes	Yes	Yes
Header relationships	No	Yes	Yes
DKIM revalidation	No	Possible from raw bytes + DNS	Yes; capture observation time
SPF evaluation	No	Usually not reliable later	Yes; client IP + MAIL FROM + HELO
Trusted Authentication-Results	No	Only with proven upstream boundary	Yes; allowlisted authserv-id/path
Attachments and MIME	No	Yes, bounded	Yes, bounded
Confidence ceiling	Content-only ceiling	Identity-aware ceiling	Highest evidence coverage

Non-goals

- The phishing engine does not decide delivery or blocking policy.
- A DMARC pass does not mean the message is benign; it means authorized use of the Author Domain.
- ARC validates a chain and its actors, not their trustworthiness or the message's safety.
- The engine does not execute attachments, render active HTML or dereference links itself.
- No pasted-text response may claim sender authentication, header analysis or attachment analysis.

3. Current project architecture and deep findings

Implemented request paths

Path	Current behavior	Risk
Web route	JSON text input, provider selection, persistence and model/rule blending.	May persist raw preview despite retention flag; fallback can look successful.
Developer v1 route	JSON text only, same detector and fallback behavior.	Contract implies a detection result even when providers fail.
Gateway adapter	Supports only text artifact and disables provider/local fallback.	More honest failure state, but still lacks full email evidence.
Browser UI	One textarea labeled for Email, SMS and URL.	Conflates capabilities; a Legitimate label and meter imply unwarranted safety.

MailGuard normalizer

- Treats label_0/legitimate_email and label_2/legitimate_url as legitimate; label_1 and label_3 as phishing.
- Collapses a mixed four-class task into binary, losing modality errors and calibration.
- For unknown labels, it guesses legitimacy unless text contains phishing, label_1 or label_3. This is a fail-open semantic guess.

Cortex generative path

- User-controlled message text is placed directly in a generative prompt; no provider-enforced schema is shown.
- The parser extracts the first brace-shaped substring. Parse failure plus the word phishing can become Phishing; other text can become Legitimate.
- Arbitrary indicator strings and risk values are accepted. Confidence normalization can mis-handle values just above one.

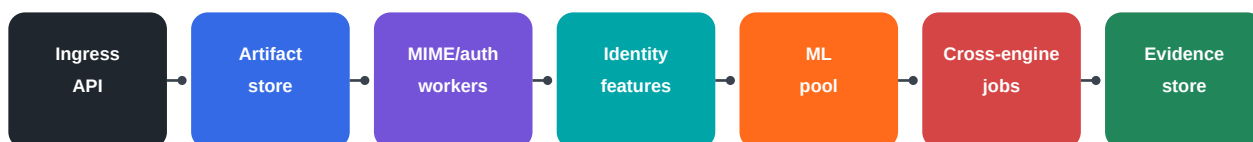
Rule and fallback path

- English regexes cover urgency, credentials, OTP, payments, KYC and a small static domain/shortener vocabulary.
- A 70/30 model/rule blend overwrites the selected provider output with uncalibrated fixed thresholds.
- There is no MIME, header trust, sender relationship, language/OOD detection, quote stripping or campaign-aware evaluation.

Diagnosis

The present implementation is a useful prototype text-risk demo. It is not yet a production email-phishing engine because artifact truth, authentication provenance, calibrated model semantics and failure behavior are incomplete.

4. Target service architecture



Fast text requests may complete synchronously; full email analysis is hybrid or asynchronous

Service boundaries

Component	Responsibility	Must not do
Ingress/API	Authenticate caller, identify input mode, stream bytes, enforce declared size.	Parse MIME in the web process or infer missing SMTP facts.
Artifact service	SHA-256, immutable object key, encryption, tenancy and retention metadata.	Store unredacted previews by default.
MIME worker	Bounded parse, raw headers, normalized text/HTML, attachment metadata.	Render active content or execute attachments.
Auth worker	SPF/DKIM/DMARC/ARC facts, DNS observations and provenance.	Convert authentication pass into a benign verdict.
Identity engine	PSL/IDNA-normalized domains and typed relationship edges.	Use string suffix matching as alignment.
ML pool	Pinned classifiers and optional semantic extractor.	Invent evidence when a model or provider fails.
Orchestrator	Child URL/image/attachment jobs, deadlines, partial completion.	Collapse specialist states into a final action.
Gateway	Policy, correlation, tenant controls and user-facing action.	Hide missing evidence or unsupported modes.

Queue topology

- Separate queues: email.parse, email.auth, email.content, child.link, child.image, child.attachment and evidence.finalize.
- Use tenant-aware fair scheduling, idempotency by artifact hash + pipeline version, bounded retries and dead-letter evidence.
- Propagate deadline budgets; finalize partial evidence instead of waiting forever for a slow child engine.

5. Canonical artifacts and bounded MIME parsing

Immutable EmailArtifact

```
{
  "artifact_id": "art...",
  "tenant_id": "tenant...",
  "input_mode": "raw_email",
  "sha256": "hex-64",
  "byte_length": 183442,
  "media_type": "message/rfc822",
  "object_ref": "encrypted://...",
  "received_at": "2026-08-11T...Z",
  "retention_policy": "ephemeral_24h",
  "pipeline_version": "phish-pipeline-1"
}
```

INITIAL parsing budgets

Limit	Initial value	Failure state
Raw .eml upload	10 MiB; async above sync text threshold	UNSUPPORTED_LIMIT
Header block	256 KiB	MALFORMED_LIMIT
MIME depth / parts	10 / 100	PARTIAL_LIMIT
Total decoded bytes	25 MiB	PARTIAL_LIMIT
Single attachment	10 MiB	CHILD_UNSUPPORTED_LIMIT
Normalized HTML	1 MiB	TRUNCATED
Parser wall time	5 seconds	FAILED_TIMEOUT
Plain text compatibility	12,000 characters initially	UNSUPPORTED_LIMIT

Parser implementation

- Use the streaming MailParser class rather than simpleParser for uploaded email; consume every attachment stream.
- Hash raw bytes before parsing. Preserve raw header lines and malformed-part observations without trusting them.

- Decode transfer encodings with cumulative budgets. Record charset, decoding errors, truncation and parser version.
- Extract text/plain and sanitized text from text/html; block remote images, scripts, forms, CSS fetches and active URLs.
- Separate quoted replies, signatures and visible new content; preserve a hash and offsets for audit.
- Never use message filenames or Content-Type as proof. Detect actual file type in the attachment specialist.

6. Authentication evidence: SPF, DKIM, DMARC and ARC

Evidence flow



Authentication answers domain authorization questions; it does not answer whether content is benign

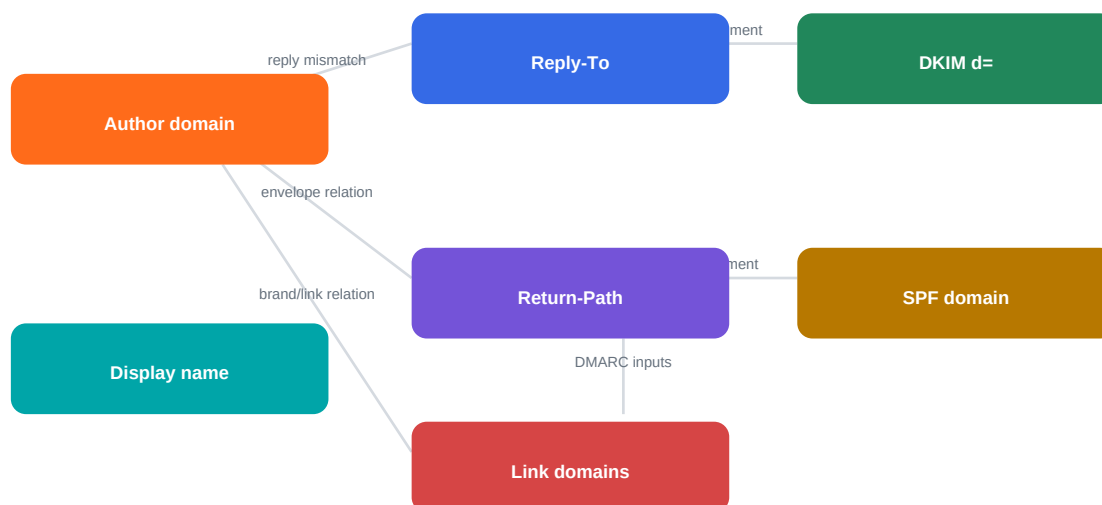
Protocol contract

Protocol	Required inputs	Output and interpretation
SPF	Trusted client IP, envelope MAIL FROM, HELO/EHLO, receiver identity, DNS and evaluation time.	pass/fail/softfail/neutral/none/temperror/pererror plus checked identity and DNS trace.
DKIM	Exact raw bytes, signatures, DNS selector keys, observation time.	Per-signature result, d=, s=, i=, algorithm, body hash and failure reason.
DMARC	RFC5322.From Author Domain, validated SPF/DKIM identifiers, policy discovery and alignment mode.	pass/fail plus policy domain and aligned mechanism; pass is not a safety assertion.
ARC	Raw ARC sets and DNS keys.	Chain validation and actor identities; not actor trustworthiness or content safety.
Authentication-Results	Allowlisted authserv-id, trusted path/boundary and header position.	A reported observation. Treat external/copied headers as untrusted text.

Critical provenance rules

- Uploaded .eml alone usually lacks trustworthy SMTP client IP and envelope facts; do not pretend to recompute SPF.
- DKIM can be checked later from raw bytes, but current DNS keys may have rotated or been revoked. Record DNS answers, TTL, resolver and observed time.
- At a trusted receiver boundary, remove/obscure forged Authentication-Results identifiers and accept only allowlisted upstream producers.
- DMARC alignment uses strict identity equality or Organizational Domain rules from RFC 9989, not a hand-written last-two-label function.
- Store protocol status and transport/DNS failures independently; temperror is not fail and fail is not phishing.

7. Sender identity and relationship graph



Typed edges

Edge	Examples	Evidence value
aligned_with	Author Domain to DKIM d= or SPF domain	DMARC mechanism and mode; strict or relaxed.
differs_from	From vs Reply-To; From vs Return-Path	Potential reply redirection or delegated sender; never malicious alone.
claims_brand	Display name/subject/body to tenant brand registry	Impersonation hypothesis with locale and ambiguity.
links_to	Message to child URL registrable domains	First-party, known vendor, unrelated, newly observed or unresolved.
sent_via	Received chain, envelope domain, infrastructure ASN	Operational relationship only when provenance is adequate.
communicated_before	Tenant-recipient to sender/domain	Behavioral baseline with privacy-preserving aggregation.

Normalization

- Canonicalize domain A-labels and U-labels, Unicode normalization, case and trailing dot; retain originals for display.
- Use a pinned Public Suffix List implementation such as tldts. Version the PSL used for every Organizational Domain decision.
- Detect mixed scripts, confusable skeletons and display-name/domain brand disagreement. Avoid automatic accusation from a single confusable.
- Model multiple From mailboxes and malformed addresses as explicit ambiguity. Do not silently pick the first value.

8. Content intelligence and deterministic features

Semantic categories

Category	Signals	Notes
Credential request	Passwords, login, recovery, session verification	Distinguish request, warning and quoted historical text.
Financial/payment	Invoice, refund, gift card, bank transfer, crypto	Capture actor, requested action, amount/currency when present.
Urgency/coercion	Deadline, suspension, penalty, secrecy	Locale-aware; urgency is common in legitimate mail.
Identity impersonation	Executive, vendor, bank, government, platform	Join with relationship and tenant brand evidence.
Out-of-band contact	New phone, WhatsApp/Telegram, reply address	Normalize and route entities; do not treat contact alone as malicious.
Attachment lure	Document review, macro, password-protected archive	Child attachment engine owns file evidence.
QR/link lure	Scan code, disguised anchor, visible/actual URL mismatch	Route QR/URLs to Link Engine with parent edge.

Deterministic feature policy

- Rules emit named observations with version, offsets, locale and confidence. They do not emit a final phishing probability.
- Replace English-only regex with locale packs and tests. Run language identification with UNKNOWN and mixed-language states.
- Strip or separately score quoted threads so an old phishing warning does not contaminate the new message.
- Measure HTML visual tricks: zero-size text, hidden anchors, visible-vs-href domain mismatch and suspicious forms after safe parsing.
- Redact secrets and PII before optional external model calls; record redaction version and whether meaning could be altered.

9. Hugging Face and model portfolio

Model selection rule

No public model card is sufficient evidence for production. Pin immutable revisions, verify labels with golden fixtures, scan model files, approve licenses and benchmark on campaign/time/tenant-separated VeriTrust data.

Recommended portfolio

Registry name	Repository / role	Parameters	Disposition
mailguard_current	Exact hidden HF_PHISHING_MAILGUARD_MODEL	Unknown until D0	Preserve only after repository, commit, task, tokenizer and labels are frozen.
mailguard_distilbert_v1	cybersectory/phishing-email-detection-distilbert_v2.4.1; latency candidate	Approx. 67M; Safetensors; 4 classes	SHADOW. Validate mixed email/URL task and label IDs; email-mode benchmark required.
phish_bert_large_shadow	ealvaradob/bert-finetuned-phishing; recall/error-diversity candidate	Approx. 336M; binary	SHADOW only. Mixed source/modalities and large cost require independent leakage and latency study.
phish_multilingual_mdeberta_v1	Private fine-tune from microsoft/mdeberta-v3-base	12 layers, hidden 768; multilingual base	Preferred trained classifier for approved target locales after data sufficiency.
phish_features_gbdv1	Private LightGBM/XGBoost over auth/header/relationship/content features	500-1500 trees INITIAL	Independent structured model; strong auditability and failure diversity.
cortex_semantic_v1	Pinned instruction model, e.g. self-hosted Mistral-7B-Instruct-v0.3	7B; temperature 0; max 128 tokens	Optional SHADOW semantic extraction only; never final verdict. Provider availability must be verified.

Why these roles are separate

- The 67M candidate is a latency baseline, not automatically the best detector.
- The large BERT candidate may add error diversity, but published aggregate metrics do not establish generalization to VeriTrust traffic.
- mDeBERTa is a base model: it must be fine-tuned on governed, locale-representative data before use.
- The feature model consumes protocol and relationship evidence unavailable to text encoders.
- A generative model is exposed to prompt injection from the email. Its bounded output can assist explanations, never define truth.

10. Exact model contracts and runtime parameters

Classifier contract

Field	Required value
Identity	repository_id + immutable revision SHA + artifact digest + tokenizer digest
Task	text-classification; explicit input mode and locale coverage
Labels	ordered id2label/label2id, positive class, rejection behavior and golden fixtures
Input	normalizer version, subject/body framing, quote policy, max tokens, truncation/chunk aggregation
Output	raw logits/probabilities, calibration version, OOD score, abstention reason and latency
Runtime	Transformers/ONNX/Triton versions, dtype, device class, batch policy and timeout
Governance	license, dataset provenance, security scan, owner, promotion state and rollback target

Recommended inference parameters

Model	Input	Runtime start	Output rules
DistilBERT candidate	Subject + new body; max 256/384; deterministic chunking	FP16/BF16 GPU or INT8 CPU after parity; batch 16-64; timeout 1.5s	Return all raw class scores; validate sum/range; no guessed labels.
mDeBERTa fine-tune	Locale token + subject + body; max 384	BF16 GPU; dynamic batch; timeout 2s	Binary or 3-state logits plus OOD head; calibrated per locale/mode.
Feature GBDT	Schema-versioned numeric/categorical vector	CPU; p95 under 20ms target	Missingness is explicit; monotonic assumptions documented if used.
Cortex semantic	Redacted bounded text; system schema; email in quoted data field	temperature 0; max_new_tokens 128; one retry only	Strict JSON schema + enums + length limits; invalid output is FAILED, never Legitimate.

```
semantic_schema = {
  "credential_request": "NONE|POSSIBLE|EXPLICIT|UNKNOWN",
  "payment_request": "NONE|POSSIBLE|EXPLICIT|UNKNOWN",
  "urgency": "NONE|LOW|HIGH|UNKNOWN",
  "impersonation_claim": "NONE|POSSIBLE|UNKNOWN",
  "evidence_spans": [{"start": 0, "end": 20, "category": "..."}]
}
# No label, no risk tier, no action, no free-form indicators.
```

11. Model registry and pre-inference resolution

Required control flow



The evidence record must identify the exact runtime artifact used - not a version resolved afterward

Registry record

```
{
  "model_version_id": "phish_multilingual_mdebarta_v1@sha256:...",
  "repository": "private/veritrust-phish-mdebarta",
  "revision": "git-sha",
  "tokenizer_digest": "sha256:...",
  "label_contract": "phish-labels-v3",
  "input_contract": "email-content-v4",
  "calibration": "temp-locale-mode-v2",
  "runtime_image": "sha256:...",
  "state": "shadow|canary|production|retired"
}
```

Promotion gates

- No mutable branch names, latest tags or provider aliases in a production record.
- Load by digest, verify tokenizer/model pairing and run golden label fixtures before readiness.
- Provider response must echo a verifiable model/revision; otherwise the evidence version is unresolved and cannot influence policy.
- Canary and rollback versions coexist. Calibration is versioned separately and never silently reused after retraining.

12. Scoring, calibration and abstention

Specialist state machine

State	Meaning	Gateway treatment
LIKELY_BENIGN	Observed evidence supports benign class within calibrated scope.	One input; never a safety guarantee.
LIKELY_PHISHING	Observed evidence supports phishing within calibrated scope.	Policy may warn/quarantine based on tenant context.
UNCERTAIN	Near decision boundary, high disagreement, OOD or incomplete evidence.	Review, collect evidence or use conservative policy.
UNSUPPORTED	Input mode, type, size, locale or encryption is unsupported.	Do not reinterpret as benign.
FAILED	Parser, provider, DNS or runtime failed.	Expose degraded coverage and apply resilience policy.

Keep sources independent

- Persist content model probability, feature model probability, auth observations, relationships, rules and child-engine evidence as separate typed items.
- Do not recreate the current fixed 70/30 blend. Fit a meta-model only after leakage-safe validation proves value and calibrate its output.
- Use temperature scaling, vector scaling or isotonic regression selected on held-out data; report ECE, Brier score and reliability plots.
- Set thresholds from explicit cost constraints: false-positive budget, phishing miss budget and review capacity. Version by tenant segment only when sample size supports it.
- Abstain on out-of-domain language, excessive truncation, invalid label map, model disagreement, severe MIME failure or missing required trusted facts.

INITIAL policy-independent bands

For shadow evaluation only: likely benign if calibrated $p_{\text{phish}} \leq 0.20$ and OOD is acceptable; uncertain for 0.20-0.70 or any evidence-quality trigger; likely phishing if $p_{\text{phish}} \geq 0.70$. These are experiment bands, not release thresholds.

13. Cross-engine routing and evidence graph

Child artifacts

Child	Extraction	Destination	Parent relationship
URL	text, HTML href/src/action, QR decode	Link Detection Engine	message contains link; part/span; visible text mismatch
Image	inline MIME, CID reference, attachment	Deepfake Engine when policy-selected	message contains image; part/hash; claimed identity context
Attachment	MIME attachment stream	Future file/malware specialist	message contains file; content hash; declared/detected type
Phone/email	normalized entities	Identity/reputation enrichment	requested contact/reply route

Routing rules

- Create stable child artifact IDs from parent hash, part index and canonical content hash; deduplicate identical children.
- The phishing worker never opens URLs. It sends canonical raw URL evidence to the Link Engine and receives versioned child evidence.
- Route images only when identity manipulation is relevant or tenant policy requests it; a marketing image should not consume deepfake capacity by default.
- Finalize when mandatory local evidence completes and either child evidence arrives or its deadline expires. Late child evidence creates a new bundle version.

- Gateway correlation uses explicit graph edges. A maximum score plus a fixed bonus is insufficient to represent relationships.

14. API and evidence data contracts

Ingress endpoints

```
POST /v2/phishing/analyze-text
Content-Type: application/json
{"subject":"...", "body":"...", "channel":"email|sms", "locale_hint":"..."}

POST /v2/phishing/analyze-eml
Content-Type: message/rfc822
X-Retention-Policy: ephemeral_24h

POST /internal/v2/phishing/receiver-event
{"raw_eml_ref":"...", "client_ip":"...", "mail_from":"...",
"hello":"...", "receiver_id":"...", "authserv_id":"...", "received_at":"..."}
```

Phishing Evidence bundle

```
{
  "schema_version": "phishing-evidence-2",
  "artifact_id": "art_...",
  "input_mode": "trusted_receiver_event",
  "state": "UNCERTAIN",
  "capabilities": {"mime":true,"spf":true,"dkim":true,"links":true},
  "observations": [{"type":"dmarc","result":"pass","provenance":"local"}],
  "model_evidence": [{"model_version_id":"...", "p_phish":0.61, "ood":0.08}],
  "relationships": [{"type":"reply_to_differs", "source":"...", "target":"..."}],
  "children": [{"artifact_id":"url_...", "engine":"link", "state":"LIKELY_PHISHING"}],
  "limitations": ["attachment_scan_pending"],
  "started_at": "...", "completed_at": "..."
}
```

Contract rules

- Use 202 Accepted + job ID for asynchronous .eml analysis; expose evidence revisions and completion state.
- Every observation includes source, producer version, time, quality and a stable machine code; explanations are additive.
- Do not return Legitimate as a default. Unknown enum values fail validation; old clients receive explicit unsupported-version errors.
- Idempotency keys, tenant ownership checks and signed object references are mandatory.

15. Data acquisition, labeling and governance

Data portfolio

Source	Use	Controls
Customer-adjudicated incidents	Primary realism, recent campaigns and tenant context	Consent/DPA, tenant isolation, redaction, access audit, retention and appeal trail.
Customer benign streams	False-positive control and business-mail diversity	Purpose limitation, sampling, PII minimization and no cross-tenant memorization.
Enron / public corpora	Legacy benign baseline and parser fixtures	License/provenance review; remove duplicates and personal data where required.
SpamAssassin public corpus	Legacy spam/ham robustness fixtures	Not a modern phishing benchmark; provenance and distribution gap documented.
cybersectony dataset	Reproduce four-label baseline	200k mixed email/URL samples; isolate modality and audit near duplicates.
ealvaradob dataset	Research diversity across email/SMS/URL/HTML	Training-only mixed sources; pin converted artifacts; do not execute remote dataset code in production.
Synthetic/red-team	Header/MIME/pathology/prompt-injection cases	Never inflate headline metrics; label as synthetic and keep separate reports.

Label ontology

- Primary: phishing, benign, uncertain, unsupported and unlabelled. Never force disputed samples into binary truth.
- Attack taxonomy: credential theft, payment/BEC, malware delivery, QR phishing, callback phishing, OAuth consent, impersonation and mixed.
- Label evidence source, adjudicator count, timestamp, campaign ID, locale, input mode and retrospective knowledge boundary.
- Use two reviewers for ambiguous/high-impact examples and security adjudication for disagreements; track label changes.
- Hash/redact before export. Maintain deletion lineage from raw artifact through training shards, embeddings, checkpoints and eval caches.

16. Training recipes

A. Email/SMS DistilBERT baseline

Parameter	INITIAL setting
Task	Separate email and SMS models, or explicit mode token; do not mix raw URLs as if they were email text.
Input	Subject + new-message body + suspicious spans; max 256 or 384; deterministic chunk aggregation.
Optimization	AdamW; learning rate search 1e-5 to 5e-5, start 2e-5; weight decay 0.01; warmup 6%; clip 1.0.
Batch/epochs	Effective batch 64; 3-5 epochs; BF16 when supported; early stop on campaign/time validation.
Robustness	Three seeds; baseline cross-entropy before class weights/focal loss; report seed variance.

B. Multilingual mDeBERTa

Parameter	INITIAL setting
Base	microsoft/mdeberta-v3-base, pinned revision and tokenizer; private sequence-classification head.
Input	Locale token + subject + normalized new body; max 384; per-locale truncation and OOD audit.
Optimization	LR search 1e-5 to 3e-5; effective batch 32; 3-5 epochs; weight decay 0.01; warmup 6%.
Sampling	Campaign-aware balanced batches without duplicating rare messages across splits.
Promotion	Locale minimum support, per-locale calibration and worst-group recall/false-positive gates.

C. Structured feature model

- Use auth categorical states, alignment, MIME anomalies, sender relationships, link evidence summaries, behavior and semantic counts.
- Start with LightGBM/XGBoost: 500-1500 trees, learning rate 0.03-0.07, 31-127 leaves, early stopping 100 rounds. Tune on grouped validation.
- Encode missing facts as missing/provenance features, not benign zeros. Use SHAP only as a debugging aid, not causal explanation.

D. Generative semantic extractor

- Do not fine-tune first. Use a strict schema, temperature 0, max 128 tokens and prompt-injection red-team set.
- If later adapted, train only on adjudicated semantic categories and evidence spans - never on Gateway actions or free-form rationales.

17. Leakage-safe splits and benchmark

Split before tokenization or augmentation

Boundary	Rule
Campaign/template	Group exact and near-duplicate body/HTML templates, kits and subjects.
Thread	All quoted/replied messages and attachments remain in one split.
Identity	Group sender domain, Link Engine registrable domain and campaign infrastructure where known.
Tenant	Hold out tenants or report tenant-generalization separately; no tenant-specific leakage.
Time	Final 30-60 days as untouched temporal test; replay delayed labels at the knowledge available then.
Dataset/source	Run leave-one-source-out audit so source artifacts do not masquerade as phishing skill.

Required metrics

- PR-AUC, ROC-AUC, precision, recall, F1 and confusion matrix, but never only aggregate accuracy.
- False-positive rate at target recall; recall at false-positive budget; cost-weighted expected loss and review volume.
- Brier score, ECE, adaptive calibration error and reliability diagrams per mode/locale/sector.
- Coverage versus selective risk for abstention; unsupported and failed rates are first-class operational metrics.
- p50/p95/p99 latency, throughput, memory, cold start, provider error rate and per-message cost.
- Slices: attack class, language, message length, HTML/plain, authentication state, forwarded mail, brand, new campaign and obfuscation.

Promotion rule

A candidate must beat the deployed baseline or add statistically useful error diversity on the untouched temporal test, meet every critical slice floor, stay calibrated after threshold selection, and pass security/load/failure drills. Published model-card metrics are context only.

18. Robustness, red-team and test plan

Test suites

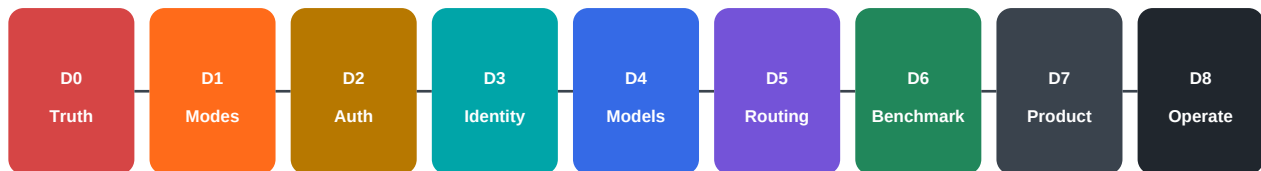
Suite	Cases	Pass condition
MIME/parser	Deep nesting, many parts, malformed boundaries, zip bombs, charsets, duplicate headers	Bounded resource use; explicit partial/malformed state; no crash.
Authentication	SPF vectors, DKIM canonicalization, expired/revoked DNS, DMARC alignment, ARC chains	Protocol fixtures match standards/library suites; provenance retained.
Identity	IDN, confusables, co.uk/private suffixes, multi-From, Reply-To shifts	Pinned normalization; no suffix/alignment false match.
Content	Unicode obfuscation, whitespace, HTML hidden text, quoted warnings, multilingual lures	Slice thresholds and abstention behavior meet gates.
LLM	Prompt injection, JSON breakouts, huge outputs, false instructions	Strict parser rejects invalid output; no user-facing benign fallback.
Cross-engine	Duplicate URLs, slow Link Engine, failed Deepfake, late evidence	Idempotent child graph; deadline and evidence revisions work.
Privacy	retain_text=false, secrets, tenant crossover, deletion	No preview leakage; deletion lineage and authorization tests pass.
Chaos/load	DNS timeout, provider 429/500, queue saturation, worker restart	Backpressure, circuit breakers and honest degraded states.

Golden fixtures

- Provider labels: one fixture per exact label, reordered score arrays, duplicates, NaN/Infinity, missing labels and unknown labels.

- Evidence snapshots: canonical artifact, parsed headers, protocol observations, relationships and child edges are schema-diffed.
- Threshold regression: lock evaluation dataset digest, calibration digest and expected operating point bounds.

19. Ordered roadmap and implementation tickets



Each gate has measurable exit criteria; production influence begins only after D6

D0-D8 delivery gates

Gate	Deliverables	Exit criteria
D0 Truth	PHS-001 exact models; PHS-002 modes; PHS-003 remove fail-open; PHS-004 schemas; PHS-005 pre-inference registry	Golden label fixtures, explicit failure states and authoritative schema migrations.
D1 Modes	PHS-006 raw .eml hash, object store and bounded MIME worker	Adversarial parser suite and retention tests pass.
D2 Auth	PHS-007 trust provenance; PHS-008 SPF/DKIM/DMARC/ARC	Protocol fixtures and trusted receiver integration pass.
D3 Identity	PHS-009 PSL/IDNA normalization and relationship graph	Confusable/alignment/relationship golden tests pass.
D4 Models	PHS-011 governed corpus, training pipelines, registry and OOD	Reproducible checkpoints and model cards produced.
D5 Routing	PHS-010 URL/image/attachment child artifacts and deadlines	End-to-end idempotent evidence graph works under partial failure.
D6 Benchmark	PHS-012 leakage-safe benchmark, calibration and threshold proposal	Security/ML/product sign-off; shadow minimum complete.
D7 Product	PHS-013 APIs/UI, capability language and review UX	Accessibility, privacy and misleading-claim review pass.
D8 Operate	PHS-014 telemetry/drift; PHS-015 load/security/release	Canary, rollback, SLOs, runbooks and incident drill pass.

First two implementation sprints

- Sprint 1: PHS-001 through PHS-005. This prevents new work from being built on unknown model semantics or dishonest failure behavior.
- Sprint 2: PHS-006 through PHS-009. This creates a real email artifact and trustworthy identity/authentication foundation.

Do not start by fine-tuning

Training before D0-D3 would optimize a content model around an incomplete artifact and label contract. Freeze truth, modes, parser, authentication and identity first; then build the corpus and benchmark.

20. Product and UI implementation

User-facing modes

UI entry	Promise	Required disclosure
Paste message text	Analyze language, requests and extracted links	No header, sender-authentication or attachment analysis.
Upload .eml	Analyze raw headers, MIME, DKIM possibilities, content and children	SPF may be unavailable; Authentication-Results trust depends on provenance.
Connected mailbox/receiver	Use trusted SMTP and upstream authentication evidence	State connected provider, time and evidence limitations.

Result presentation

- Use evidence states such as Likely phishing, Uncertain, Likely benign, Unsupported and Analysis failed. Avoid a green Legitimate certificate.
- Show evidence coverage: content, headers, authentication, links, images and attachments as observed/pending/unavailable/failed.
- Explain high-value relationships: Reply-To differs, DKIM aligned, link domain unrelated. Do not expose raw secret-bearing content.
- Separate model probability from confidence/coverage. Show why uncertainty exists and what upload/connection would add evidence.
- Allow user correction and analyst adjudication with reason codes; never train directly from unreviewed thumbs-up/down.

21. Scaling and deployment topology

Workload classes

Class	Execution	Initial SLO target
Plain text fast path	API + CPU/GPU classifier + URL extraction; no network dereference	p95 under 1.5s after warmup
Raw .eml local evidence	Artifact store + MIME + DKIM/content/identity workers	p95 under 5s for messages within budgets
Trusted receiver	Receiver event + SPF/DNS + full local evidence	p95 under 5s excluding slow children
Child enrichment	Link/image/file queues with separate deadlines	Evidence revision typically under 15s

Deployment controls

- Keep MIME/auth workers isolated from web/API processes; run attachments in a stronger future sandbox.
- Use warm model pools, dynamic batching, admission control and per-tenant quotas. Scale on queue age and GPU utilization, not CPU alone.
- Cache DKIM/DMARC/SPF DNS by TTL with negative caching limits and resolver circuit breakers; store observation provenance.
- Use content-addressed child deduplication with tenant/privacy constraints; never share raw message content across tenants.
- Canary by model version and tenant cohort; rollback is a registry pointer plus preserved previous runtime image.

22. Security, privacy and licensing

Threat controls

Threat	Control
MIME/decoder denial of service	Streaming parse, cumulative budgets, depth/part/time limits, worker memory/CPU quotas.
HTML active content/tracking	Never render directly; sanitize; block remote resources, forms, scripts, CSS fetches and navigation.
Prompt injection	Generative model is non-authoritative; quote/redact input; strict schema; invalid output fails closed.
Forged auth headers	Trust-boundary allowlist and path validation; external Authentication-Results is untrusted text.
Tenant/data leakage	Tenant-scoped object keys/queues/caches, encryption, signed access, audit and deletion lineage.
Secrets/PII	Minimal default retention, no preview persistence, redaction before external providers, regional routing.
Model supply chain	Pinned revisions/digests, Safetensors preference, isolated scan/load, SBOM and license approval.
Training contamination	Source/campaign/time splits, poisoning review, provenance and reproducible data manifests.

Licensing decisions

- Apache-2.0 or MIT on a model card is only the model-repository license; training sources may carry separate rights and privacy obligations.
- The cybersectony and ealvaradob resources require a documented upstream-source and redistribution review before commercial training.
- Qwen2.5-3B-Instruct currently shows a qwen-research license on its card, so do not substitute it without legal approval. The Mistral candidate shows Apache-2.0 but still requires operational qualification.
- Record every external inference provider's retention, training, region, subprocessors, revision guarantees and breach terms.

23. Observability, drift and incident operations

Telemetry

Layer	Metrics
Ingress	mode/tenant/channel counts, bytes, rejected limits, idempotency collisions
Parser	parts/depth/decoded bytes, truncation, malformed rate, time and memory
Auth	SPF/DKIM/DMARC/ARC states, DNS latency/errors, trusted-header rate, alignment
Models	version, p_phish distribution, OOD, disagreement, abstention, latency, batch and provider failure
Children	URLs/images/files per message, completion/deadline/failure and late revisions
Quality	delayed precision/recall, false positives, campaign misses, calibration and coverage
Privacy	retention class, redaction failures, external calls, deletion completion and access audit

Drift and retraining

- Monitor input embeddings/features, language, auth-state mix, campaign novelty, provider version and label delay.
- Alert on calibration drift and coverage loss before headline accuracy. A falling supported/observed rate can hide quality loss.
- Retraining is triggered by sustained slice degradation or campaign coverage, not a fixed calendar alone. Preserve an untouched rolling temporal test.

Runbooks

- Provider outage: circuit break, emit FAILED/DEGRADED, continue deterministic/auth evidence and notify Gateway coverage policy.
- DNS outage: cache within TTL, distinguish temperror, pause DMARC conclusions and record resolver failure.

- False-positive spike: freeze promotion, rollback model/calibration, preserve artifacts and compare slices/versions.
- Data incident: revoke access, stop external calls, execute deletion lineage, preserve audit evidence and follow notification policy.

24. Interactive implementation worksheet

Fill these fields before coding model-dependent behavior

The current repository does not reveal the exact Hugging Face repositories or revisions. These interactive fields become the signed D0 record. Save a filled copy under the architecture decision record.

Current MailGuard contract

Repository ID

Immutable revision

Task / modality

Ordered labels

Tokenizer / max tokens

Provider / runtime

License approval

Dataset provenance

Current Cortex contract

Repository ID

Immutable revision

Provider / endpoint

Exact role

JSON schema version

Max tokens / timeout

License approval

Retention / region

Target operating context

Enabled input modes

Locales / geographies

Primary customers/use

False-positive budget

Phishing miss budget

Peak messages/minute

Fast-path p95

Full-analysis deadline

Review capacity/day

Retention requirement

Trusted receiver and infrastructure

Receiver ingress

SMTP metadata source

Trusted authserv-ids

ARC policy

DNS resolver/region

Object-store region

Queue / worker platform

External provider DPA

25. Interactive production checklist

Truth, inputs and failure behavior

- ☐ Exact MailGuard and Cortex repositories, commits, tasks, tokenizers, labels and licenses are frozen
- ☐ Provider label golden fixtures reject unknown, duplicate, missing and non-finite outputs
- ☐ Plain text, raw .eml and trusted receiver modes have versioned capability contracts
- ☐ Heuristic/provider failure cannot return ok=true, Legitimate or a fabricated probability
- ☐ Model registry resolves and authorizes immutable version before inference
- ☐ Authoritative migrations and evidence schemas are present and tested
- ☐ retain_text=false stores no raw preview or hidden content
- ☐ Raw .eml is hashed before parsing and stored under tenant-scoped encryption
- ☐ Streaming MIME parser budgets pass adversarial fixtures
- ☐ HTML is sanitized and no active/remote content is rendered
- ☐ SPF uses trusted client IP, MAIL FROM and HELO at the receiver boundary
- ☐ DKIM preserves raw bytes, DNS observations and per-signature results
- ☐ DMARC implements RFC 9989 alignment and never implies message safety
- ☐ Authentication-Results is accepted only across a configured trust boundary
- ☐ ARC validation is represented separately from actor trust and content safety
- ☐ PSL/IDNA versioning and confusable tests cover sender and link domains
- ☐ From, Reply-To, Return-Path, DKIM, SPF and link relations form typed edges
- ☐ URL child artifacts route to Link Engine without dereference in phishing worker
- ☐ Image and attachment routing is bounded, policy-selected and idempotent
- ☐ Training split groups campaign, template, thread, identity, tenant, source and time
- ☐ Per-mode/locale/attack/auth metrics, calibration and abstention gates pass
- ☐ Every model artifact, tokenizer, calibration and runtime image has a digest
- ☐ Cortex is schema-bounded, prompt-injection tested and non-authoritative
- ☐ UI displays evidence coverage and never presents a safety certificate
- ☐ Load, chaos, privacy, security, canary, rollback and incident drills pass

Production definition of done

All P0/P1 items are closed; D0-D8 exit criteria are signed; the untouched temporal benchmark and critical slices pass; failure/degraded behavior is honest; privacy/license approvals are recorded; canary and rollback are tested; and the Gateway is the only component that decides action.

References and source notes

Repository findings were derived from the VeriTrust workspace and the phishing section (pages 9-11) of *VeriTrust Four Core Detection Architecture Blueprint*. Exact environment-configured model identities were not exposed in repository code and are intentionally marked unresolved.

1. VeriTrust Four Core Detection Architecture Blueprint, phishing detection section, pages 9-11
2. RFC 9989 - Domain-Based Message Authentication, Reporting, and Conformance (DMARC), May 2026 <https://datatracker.ietf.org/doc/html/rfc9989>
3. RFC 7208 - Sender Policy Framework (SPF) <https://datatracker.ietf.org/doc/html/rfc7208>
4. RFC 6376 - DomainKeys Identified Mail (DKIM) Signatures <https://datatracker.ietf.org/doc/html/rfc6376>
5. RFC 8601 - Message Header Field for Indicating Message Authentication Status <https://datatracker.ietf.org/doc/html/rfc8601>
6. RFC 8617 - The Authenticated Received Chain (ARC) Protocol <https://datatracker.ietf.org/doc/html/rfc8617>
7. RFC 5322 - Internet Message Format <https://datatracker.ietf.org/doc/html/rfc5322>
8. RFC 2045 and RFC 2046 - Multipurpose Internet Mail Extensions <https://datatracker.ietf.org/doc/html/rfc2045>
9. Nodemailer MailParser documentation - streaming and buffered parser behavior <https://nodemailer.com/extras/mailparser>
10. Postal Systems mailauth - SPF, DKIM, DMARC and ARC implementation <https://github.com/postalsys/mailauth>
11. tldts - Public Suffix List and IDNA-aware domain parsing <https://www.npmjs.com/package/tldts>
12. Hugging Face model card - cybersectony/phishing-email-detection-distilbert_v2.4.1 https://huggingface.co/cybersectony/phishing-email-detection-distilbert_v2.4.1
13. Hugging Face dataset card - cybersectony/PhishingEmailDetectionv2.0 <https://huggingface.co/datasets/cybersectony/PhishingEmailDetectionv2.0>
14. Hugging Face model card - ealvaradob/bert-finetuned-phishing <https://huggingface.co/ealvaradob/bert-finetuned-phishing>
15. Hugging Face dataset card - ealvaradob/phishing-dataset <https://huggingface.co/datasets/ealvaradob/phishing-dataset>
16. Hugging Face model card - microsoft/mdeberta-v3-base <https://huggingface.co/microsoft/mdeberta-v3-base>
17. Hugging Face model card - mistralai/Mistral-7B-Instruct-v0.3 <https://huggingface.co/mistralai/Mistral-7B-Instruct-v0.3>
18. Apache SpamAssassin public mail corpus <https://spamassassin.apache.org/old/publiccorpus/>
19. CMU Enron email dataset <https://www.cs.cmu.edu/~enron/>
20. NIST AI Risk Management Framework <https://www.nist.gov/itl/ai-risk-management-framework>
21. OWASP File Upload Cheat Sheet https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html

Implementation starting point

Begin with PHS-001 through PHS-005: freeze model semantics, define modes, remove successful fallbacks, establish schemas and resolve the model registry before inference. Then implement the immutable .eml and authentication foundation. Training begins only after artifact and identity truth are stable.

END OF HANDBOOK